



Architectures et Administration des BDD

Présenté par:

Amal HALFAOUI (Epse GHERNAOUT)

Amal.halfaoui@univ-tlemcen.dz

amal.halfaoui@gmail.com

Université Tlemcen

-Ing 3-

-La gestion des droits
d'accès aux BDD-

La gestion des droits d'accès

1. Gestion des utilisateurs
2. Gestion des profils
3. Gestion des privilèges
4. Gestion des rôles

La gestion des droits d'accès

- Sélectionner et répartir les droits des utilisateurs de la base de données afin d'assurer la **confidentialité** des données → **qui** peu faire **quoi**
- Assurée par le DBA (DataBase Administrator)

La gestion des droits d'accès

Plusieurs mécanismes pour assurer le contrôle:

- Authentification
- Autorisation
- Vues
- Sauvegardes et restaurations
- Intégrité des données
- Cryptage

La gestion des droits d'accès

- **Authentication** : Gestion des comptes **utilisateurs** (login et mot de passe) → **qui?**
- **Autorisations** : Gestion des **profils**, des **privilèges** et **rôles** (contrôle l'accès aux objets et au système) → **quoi?**

-Gestion des utilisateurs-

Gestion des utilisateurs

- Un utilisateur (User) sera identifié par son nom (Username) et un mot de passe permettant de se connecter, puis d'exécuter des instructions et d'accéder aux données sous réserve d'avoir reçu des **privileges**.
- Un schéma (collection d'objet) = Utilisateur qui est le propriétaire (Owner)
- L'utilisateur et le schéma ont le même nom qui est défini au moment de la création de l'utilisateur

Classification des users

Des utilisateurs avec des privilèges différents:

- Les administrateurs de la base: les comptes livrés par oracle
 - l'utilisateur **SYS**, propriétaire des tables et des vues du dictionnaire il a le rôle **SYSDBA**
 - l'utilisateur **SYSTEM**, qui a le rôle **DBA**
- Les développeurs qui interagissent avec les DBA (droits, stockage, optimisation, sécurité, etc.).
- Les utilisateurs finaux qui doivent se connecter via des applications

Création des utilisateurs

- Choisir un nom d'utilisateur
- Choisir une méthode d'authentification
- Choisir les TABLESPACES qui vont être utilisées par l'utilisateur
- Définir les quotas sur chaque TABLESPACE
- Définir les TABLESPACES par défaut de l'utilisateur
- Assigner les rôles et privilèges à l'utilisateur

Méthodes d'authentification

Deux méthodes d'authentification:

- Authentification par **la base de données** (plus courant, c'est le mode par défaut): mots de passes stockés par Oracle

```
CREATE USER ahmed IDENTIFIED BY abc123
```

- Authentification par **le système d'exploitation** : se base sur l'authentification de l'utilisateur par le système d'exploitation

```
CREATE USER ahmed IDENTIFIED BY EXTERNALLY
```

Création d'un utilisateur

Syntaxe complète avec options

```
CREATE USER utilisateur
IDENTIFIED { BY password | EXTERNALLY }
[ DEFAULT TABLESPACE tablespace]
[ TEMPORARY TABLESPACE tablespace]
[ QUOTA {valeur [K|M] | UNLIMITED } ON
tablespace] ...
[ PROFILE nom_profil ] [ PASSWORD EXPIRE ]
[PASSWORD EXPIRE]
[ACCOUNT {LOCK | UNLOCK}]
```

Création d'un utilisateur

- **DEFAULT TABLESPACE:** Espace disque où l'utilisateur crée ses objet par défaut
- **TEMPORARY TABLESPACE:** Espace disque temporaire par défaut.
- **QUOTA:** Définit l'espace maximum alloué à l'utilisateur pour chaque tablespace
- **PROFILE:** Nom du profil de l'utilisateur associé (Sinon le profil DEFAULT est affecté)
- **PASSWORD EXPIRE:** Forcer le changement de mot de passe à la prochaine connexion (Le DBA peut aussi changer ce mot de passe)
- **ACCOUNT{Lock | Unlock}:** Verrouiller, déverrouiller le compte d'un utilisateur Oracle

Création d'un utilisateur

- Exemple 1: syntaxe minimale avec clauses obligatoires

```
CREATE USER AMAL IDENTIFIED BY Tempo
```

- Exemple 2: syntaxe avec clauses supplémentaires

```
CREATE USER Ahmed IDENTIFIED BY abc123  
DEFAULT TABLESPACE data  
QUOTA UNLIMITED ON data  
PASSWORD EXPIRE;
```

Modification d'un utilisateur

Les clauses sont les mêmes que pour la création.

```
ALTER USER nom  
[IDENTIFIED { BY mot_de_passe | EXTERNALLY } ]  
[DEFAULT TABLESPACE nom_tablespace ]  
[TEMPORARY TABLESPACE nom_tablespace ]  
[QUOTA { valeur [K|M] | UNLIMITED } ON  
nom_tablespace ]  
[PROFILE nom_profil ] [ PASSWORD EXPIRE ]  
[ACCOUNT { LOCK | UNLOCK } ] ;
```

Modification d'un utilisateur

- Exemple 1: Modification du mot de passe d'un utilisateur

```
ALTER USER AMAL IDENTIFIED BY tempo  
PASSWORD EXPIRE;
```

- Exemple 2: Modification du tablespace par défaut et attribution de quotas

```
ALTER USER Ahmed  
DEFAULT TABLESPACE test  
QUOTA UNLIMITED ON test  
QUOTA 10M ON data;
```


Modification d'un utilisateur

- Exemple 1: Modification du mot de passe d'un utilisateur

```
ALTER USER AMAL IDENTIFIED BY tempo  
PASSWORD EXPIRE;
```

- Exemple 2: Modification du tablespace par défaut et attribution de quotas

```
ALTER USER Ahmed  
DEFAULT TABLESPACE test  
QUOTA UNLIMITED ON test  
QUOTA 10M ON data;
```

Suppression d'un utilisateur

```
DROP USER nom [ CASCADE ] ;
```

- Si l'utilisateur possède des objets, l'option CASCADE doit être présente pour forcer la suppression préalable des objets.
- Un utilisateur actuellement connecté ne peut pas être supprimé

Informations sur les utilisateurs

Vues du dictionnaire de données

- DBA_USERS : informations sur les utilisateurs;
- DBA_TS_QUOTAS : informations sur les quotas des utilisateurs

-Profils-

Profil

- Un profil est un concept Oracle qui permet à l'administrateur d'une base de contrôler **la consommation des ressources systèmes** et des **mots de passes** de chaque utilisateur
- Ensemble de limites de ressources
- Ils sont affectables aux utilisateurs : il ne peut être attribué à un utilisateur qu'un **seul** profil
- Les utilisateurs qui n'ont pas explicitement un profil, ont le profil DEFAULT
- Toutes les limites non spécifiées d'un profil ont les valeurs du profil DEFAULT

Contrôler l'activité des utilisateurs en limitant les ressources auxquelles ils ont accès :

- Le temps CPU
- Le nombre maximal de blocs lus
- Le nombre de session par utilisateur
- La durée d'une connexion
- La durée sans occupation autorisée
- Le nombre maximal d'octets d'espace privé

Création de profil

Syntaxe

```
CREATE PROFILE nomProfil LIMIT  
{Paramètre {integer | UNLIMITED | DEFAULT}},  
{Paramètre {expression | UNLIMITED |  
            DEFAULT}} , .. ;
```

Profil (paramètres ressources)

Paramètre	Description
SESSIONS_PER_USER	Nombre max de sessions simultanées autorisées
CPU_PER_SESSION	Temps CPU max (en centisecondes) par session
CPU_PER_CALL	Temps CPU max (en centisecondes) qu'un appel (requête ou PL/SQL) peut consommer.
CONNECT_TIME	Temps max (en minutes) qu'une session peut durer.
IDLE_TIME	Temps max (en minutes) pendant lequel une session peut rester inactive.
LOGICAL_READS_PER_SESSION	Nombre max de lectures de blocs en mémoire par session.
LOGICAL_READS_PER_CALL	Nombre max de lectures logiques autorisées pour un appel (requête ou PL/SQL).
PRIVATE_SGA	Quantité max de mémoire SGA pour les objets privés d'un utilisateur (en octets).
COMPOSITE_LIMIT	Limite combinée des ressources consommées par un utilisateur

Profil (paramètres Mot de passe)

Paramètre	Description
FAILED_LOGIN_ATTEMPTS	Nombre maximum de tentatives de connexion échouées avant que le compte ne soit verrouillé.
PASSWORD_LIFE_TIME	Durée de validité d'un mot de passe (en jours).
PASSWORD_GRACE_TIME	Nombre de jours de période de grâce pendant lesquels l'utilisateur peut changer un mot de passe expiré avant son blocage.
PASSWORD_REUSE_TIME	Nombre de jours avant qu'un mot de passe précédemment utilisé puisse être réutilisé.
PASSWORD_REUSE_MAX	Nombre de changements de mot de passe requis avant qu'un ancien mot de passe puisse être réutilisé.
PASSWORD_LOCK_TIME	Durée (en jours) pendant laquelle un compte reste verrouillé après avoir atteint le nombre maximal de tentatives échouées.
PASSWORD_VERIFY_FUNCTION	Nom d'une fonction PL/SQL personnalisée utilisée pour valider les règles de complexité du mot de passe.

Création profil (Exemple)

```
CREATE PROFILE profil_Etudiant LIMIT  
SESSIONS_PER_USER          3  
CPU_PER_CALL                3000  
CONNECT_TIME                45  
LOGICAL_READS_PER_CALL     1000  
PRIVATE_SGA                 1024  
IDLE_TIME                   40  
FAILED_LOGIN_ATTEMPTS      5  
PASSWORD_LIFE_TIME          70  
PASSWORD_REUSE_TIME         60  
PASSWORD_REUSE_MAX          UNLIMITED  
PASSWORD_LOCK_TIME          1/24  
PASSWORD_GRACE_TIME         10;
```

Création profil (Exemple)

- **SESSIONS_PER_USER 3** : 3 sessions simultanées
- **CPU_PER_CALL 3000** : Un appel système ne peut pas consommer plus de 30 secondes de CPU.
- **CONNECT_TIME 45** : Une session est automatiquement terminée si elle dure plus de 45 minutes.
- **LOGICAL_READS_PER_CALL 1000** : Un appel système ne peut lire plus de 1 000 blocs de données en mémoire et sur le disque
- **PRIVATE_SGA 1024** : Chaque session ne peut allouer plus de 1 M de mémoire en SGA.
- **IDLE_TIME 40** : 40 minutes d'inactivité maximum sont autorisées pour chaque session
- **FAILED_LOGIN_ATTEMPTS 5** : 5 tentatives de connexion avant blocage du compte
- **PASSWORD_LIFE_TIME 70** : Le mot de passe est valable pendant 70 jours
- **PASSWORD_REUSE_TIME 60** : Il faudra attendre 60 jours avant qu'il puisse être utilisé à nouveau.
- **PASSWORD_REUSE_MAX UNLIMITED**
- **PASSWORD_LOCK_TIME 1/24** : 1h d'interdiction d'accès après que les 5 tentatives de connexion ont été atteintes.
- **PASSWORD_GRACE_TIME 10** : La période qui prolonge l'utilisation du mot de passe avant son changement est de 10 jours.

Attribution du profil à un utilisateur

- L'affectation du profil à un utilisateur se fait ou bien au moment de la création de l'utilisateur ou bien après par une modification

Syntaxe

```
ALTER USER nomuser PROFILE NomProfil
```

Exemple

```
ALTER USER AMAL PROFILE profil_Etudiant;
```

Gestion du profil

- **Modification**

```
ALTER PROFILE nomProfil LIMIT  
{Paramètre {integer | UNLIMITED | DEFAULT}},  
{Paramètre {expression | UNLIMITED |  
            DEFAULT}} , . . . ;
```

- **Suppression**

```
DROP PROFILE nomProfil [cascade] ;
```

CASCADE permet de supprimer le profil même s'il est attribué à des utilisateurs (option obligatoire dans ce cas) et affecte le profil **DEFAULT** à ces derniers.

Informations sur les profils

Vues du dictionnaire de données

- dba_profiles,
- resource_cost
- User_ressource_limit

-Privilèges-

Privilèges

- Droits attribués à un utilisateur d'exécuter un ensemble donné d'ordres SQL ou d'accéder à certains objets de la base de données
- Un privilège peut être attribué soit directement à un **utilisateur**, soit à un **rôle**
- Deux niveaux de privilèges :
 - **Les privilèges système**
 - **Les privilèges objet**

Privilèges système

Permettre à un utilisateur **d'agir sur les définitions des objets** de la base.

Exp: autoriser un utilisateur à créer des users, tablespaces, tables, des vues, des index..

Attribution privilège système

Syntaxe

```
GRANT {privilègeSystème | nomRôle | ALL PRIVILEGES}  
[ {privilègeSystème | nomRôle | ALL PRIVILEGES} ] ...  
TO {utilisateur | nomRôle | PUBLIC} [ {utilisateur |  
nomRôle | PUBLIC} ] ...  
[ IDENTIFIED BY motdepasse ]  
[ WITH ADMIN OPTION ] ;
```

- privilègeSystème : description du privilège système (exemple CREATE TABLE, CREATE SESSION, etc.).
- **ALL PRIVILEGES** : tous les privilèges système.
- PUBLIC: pour attribuer le(s) privilège(s) à tous les utilisateurs.
- **IDENTIFIED BY** désigne un utilisateur encore *inexistant* dans la base. Cette option n'est pas valide si le bénéficiaire est un rôle ou est PUBLIC.
- **WITH ADMIN OPTION**: permet d'attribuer aux bénéficiaires le droit de *retransmettre* le(s) privilège(s) reçu(s) à une tierce personne (utilisateur(s) ou rôle(s)).

Attribution privilège système

Exemple

```
GRANT CREATE SESSION TO Amal;
```

```
GRANT CREATE SESSION, CREATE TABLE,  
CREATE VIEW TO Tariq WITH ADMIN OPTION;
```

Tariq peut ensuite faire :

```
GRANT CREATE SESSION TO Dev1;
```

Révocation de privilèges système

Syntaxe

```
REVOKE {privilègeSystème | nomRôle | ALL PRIVILEGES}  
 [{privilègeSystème | nomRôle | ALL PRIVILEGES}]...  
FROM {utilisateur | nomRôle | PUBLIC} [{utilisateur |  
 nomRôle | PUBLIC}]...;
```

- **ALL PRIVILEGES** (valable si l'utilisateur ou le rôle ont tous les privilèges système).
- **PUBLIC** pour annuler le(s) privilège(s) à chaque utilisateur ayant reçu ce(s) privilège(s) par l'option PUBLIC

Exemple

```
REVOKE CREATE SESSION FROM dev1, Tariq;
```

Privilèges objet

Permettre à un utilisateur **d'exécuter une action particulière sur un objet** qui n'appartient pas à son schéma. comme une table, vue, fonction, séquence, procédure, package d'un schéma.

Exp :

- Autoriser un utilisateur à consulter des tables,
- Permettre à un utilisateur de faire des mises à jour, des Références à des tables

Attribution de privilèges objet

Syntaxe

```
GRANT {privilègeObjet | nomRôle | ALL PRIVILEGES}  
[ ({colonne1[,colonne2]...}) ]  
[, {privilègeObjet | nomRôle | ALL PRIVILEGES}  
[ ({colonne1[,colonne2]...}) ] ...  
ON { [schéma.] nomobjet }  
TO { utilisateur | nomRôle | PUBLIC } [, { utilisateur |  
nomRôle | PUBLIC } ] ...  
[ WITH GRANT OPTION ] ;
```

- **privilègeObjet** : description du privilège objet (ex: SELECT, DELETE, etc.).
- **ALL PRIVILEGES** : donne **tous** les privilèges à l'objet en question.
- **PUBLIC**: pour attribuer le(s) privilège(s) à tous les utilisateurs.
- **WITH GRANT OPTION**: permet d'attribuer aux bénéficiaires le droit de **retransmettre** le(s) privilège(s) reçu(s) à une tierce personne (utilisateur(s) ou rôle(s)).

Attribution de privilèges objet

Exemple

- Schéma Mohammed: contient la table Pilote(brevet, nom, age, ville)
- Schéma Tariq: contient la table qualifications (TypeQualif, brevet)

```
GRANT REFERENCES (brevet) , UPDATE (ville) ,  
SELECT ON Mohammed.Pilote  
TO tariq;
```

- L'utilisateur Tariq peut modifier la ville de la table Pilote du schéma mohammed

```
UPDATE Mohammed.pilote  
SET ville= 'Oran' WHERE brevet = 'P3' ;
```

- L'utilisateur Tariq peut déclarer une clé étrangère vers la table pilote du schéma mohammed

```
ALTER TABLE qualifications ADD CONSTRAINT  
fk_pilote_mohammed FOREIGN KEY(brevet)  
REFERENCES Mohammed.Pilote(brevet ) ;
```

Révocation de privilèges objet

Syntaxe

```
REVOKE {privilègeObjet | nomRôle | ALL PRIVILEGES}  
[ ({colonne1[,colonne2]...}) ]  
[, {privilègeObjet | nomRôle | ALL PRIVILEGES}  
[ ({colonne1[,colonne2]...}) ]...  
ON { [schéma.] nomobjet }  
FROM {utilisateur | nomRôle | PUBLIC}  
[, {utilisateur | nomRôle | PUBLIC}]...  
[CASCADE CONSTRAINTS] [FORCE];
```

- **CASCADE CONSTRAINTS** concerne les privilèges **REFERENCES** ou **ALL PRIVILEGES**. Cette option permet de supprimer la contrainte référentielle entre deux tables de schémas distincts
- **FORCE**: concerne les privilèges **EXECUTE** sur les types (extensions SQL3). En ce cas, tous les objets dépendants (types, tables ou vues) sont marqués **INVALID** et les index sont notés **UNUSABLE**.

Révocation de privilèges objet

Exemple

- L'utilisateur Tariq ne peut plus ni modifier ni lire la table Pilote du schéma mohammed

```
REVOKE UPDATE, SELECT ON Pilote FROM tariq;
```

- L'utilisateur Tariq ne peut plus bénéficier de la table Pilote du schéma Mohammed en tant que référence (l'option CASCADE CONSTRAINT est requise).

```
REVOKE REFERENCES ON Pilote FROM tariq  
CASCADE CONSTRAINTS;
```

Révocation de privilèges en cascade

Retirer les droits acquis par transmission

- **Pas de retrait en cascade des privilèges Système** : Le retrait d'un privilège acquis par **WITH ADMIN OPTION** ne peut se faire en cascade : Si un utilisateur U1 a affecté un privilège P1 à U2 et U2 l'a affecté à U3, la révocation de P1 à U2 n'entraîne pas la révocation de P1 à U3
- **Retrait en cascade des privilèges Objets** : Le retrait d'un privilège acquis avec l'option **WITH GRANT OPTION**, à un utilisateur qui lui-même l'a affecté à un autre se fait en cascade : le retrait à U2 entraîne le retrait à U3

Privilèges Prédéfinis

- Oracle propose des privilèges prédéfinis pour faciliter la gestion des droits.

Nom	Privilèges
GRANT ANY PRIVILEGE	Autorisation d'attribuer tout privilège système à d'autres.
GRANT ANY OBJECT PRIVILEGE	Autorisation d'attribuer tout privilège objet à d'autres..
COMMENT ANY TABLE	Commenter une table, vue ou colonne de tout schéma.
SELECT ANY DICTIONARY	Interroger les objets du dictionnaire des données (schéma SYS).
SYSDBA	ALTER DATABASE OPEN MOUNT BACKUP CREATE DATABASE ARCHIVELOG RECOVERY CREATE SPFILE RESTRICTED SESSION
SYSOPER	Idem sauf CREATE DATABASE.

Privilèges Prédéfinis

Exemple

```
GRANT GRANT ANY OBJECT PRIVILEGE,  
        GRANT ANY PRIVILEGE TO Tariq;
```

```
REVOKE GRANT ANY OBJECT PRIVILEGE,  
        GRANT ANY PRIVILEGE FROM tariq;
```

Informations sur les privilèges

Vues du dictionnaire de données

- dba_tab_privs

Exp :

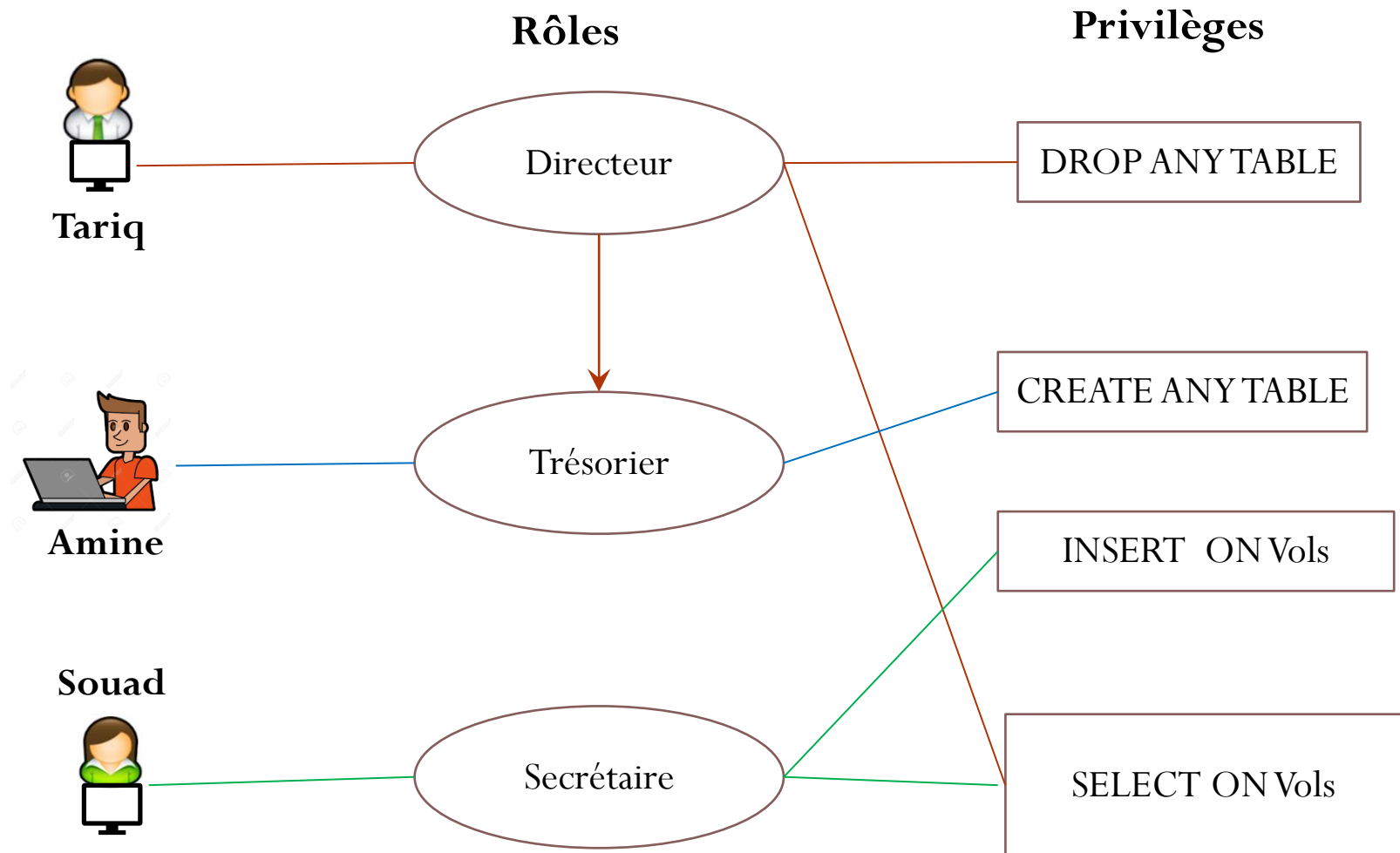
```
SELECT * FROM sys.dba_tab_privs WHERE  
table_name = 'PILOTE'
```

-Rôles -

Rôles

- Un rôle (role) est un **ensemble nommé** de privilèges (système ou objets).
- Un rôle est accordé à un ou plusieurs utilisateurs, voire à tous (utilisation de PUBLIC). Ce mécanisme **facilite** et **centralise** la gestion des privilèges.
- Un rôle peut être aussi attribué à un autre rôle pour transmettre davantage de droits

Rôles



Rôles

Etapes pour utiliser les rôles:

- créer le rôle (CREATE ROLE) ;
- l'alimenter de privilèges système ou objets par GRANT;
- l'attribuer par GRANT à des utilisateurs (voire à tous avec PUBLIC), ou à d'autres rôles;
- lui ajouter éventuellement de nouveaux privilèges système ou objets par GRANT.

Création d'un rôle

Syntaxe

```
CREATE ROLE nomRole  
[NOT IDENTIFIED |  
  IDENTIFIED{BY motdePasse|EXTERNALLY} ]
```

- **NOT IDENTIFIED** indique que l'utilisation de ce rôle est autorisée sans mot de passe.
- **IDENTIFIED** signale que l'utilisateur doit être autorisé par une méthode

RQ: Il n'est pas possible de donner le privilège REFERENCES à un rôle.

Création et attribution de rôles Exemple

- Création des rôles

```
CREATE ROLE Directeur IDENTIFIED BY PWD;  
CREATE ROLE Tresorier;  
CREATE ROLE Secrétaire;
```

- Attribution des Privilèges aux Rôles

```
GRANT DROP ANY TABLE TO Directeur;  
GRANT CREATE ANY TABLE TO Tresorier;  
GRANT INSERT, SELECT ON Vols TO Secrétaire;
```

- Alimentation d'un rôle avec d'autres rôles

```
GRANT Directeur TO Tresorier;
```

- Attribution des rôles aux utilisateurs

```
GRANT Directeur TO Tariq;  
GRANT Tresorier TO Amine WITH ADMIN OPTION;  
GRANT Secrétaire TO Souad;
```

Révocation d'un rôle

Pour pouvoir annuler un rôle, vous devez détenir au préalable ce rôle avec l'option ADMIN OPTION ou avoir reçu le privilège système GRANT ANY ROLE.

Exemple

```
REVOKE INSERT ON VOLS from Secretaire  
REVOKE Directeur FROM Tresorier;  
REVOKE Directeur FROM Tariq;
```

Modification et suppression d'un rôle

Syntaxe

- Modification

```
ALTER ROLE nomRole  
[NOT IDENTIFIED |  
IDENTIFIED{BY motdePasse|EXTERNALLY}] ;
```

- Suppression

```
DROP ROLE nomRole;
```

Pour pouvoir modifier ou supprimer un rôle vous devez en être propriétaire ou en bénéficier via l'option WITH ADMIN OPTION. Le privilège ALTER ANY ROLE ou DROP ANY ROLE vous donne le droit de Modifier ou supprimer un rôle dans tout schéma

Informations sur les privilèges

Vues du dictionnaire de données

- dba_roles, user_role_privs,
- dba_role_privs,
- role_role_privs,
- role_sys_privs,
- role_tab_privs,
- session_roles